

2.

FUNDAMENTALS OF THE PCI DSS

What are the PCI DSS?



FUNDAMENTALS

FUNDAMENTALS FUNDAMENTALS OF THE PCI DSS

What are the PCI DSS, in practical terms? They can be considered a set of standards, in terms of our security controls.

- They only apply to the parts of the organization that deal with card data, and they tell us what to do to protect those data;

After an assessment, an organization will find out which of the 12 requirements they must comply with.

- In a worst-case scenario, all 12!
- Then, they implement security practices and controls to comply with those requirements;

FUNDAMENTALS

FUNDAMENTALS OF THE PCI DSS

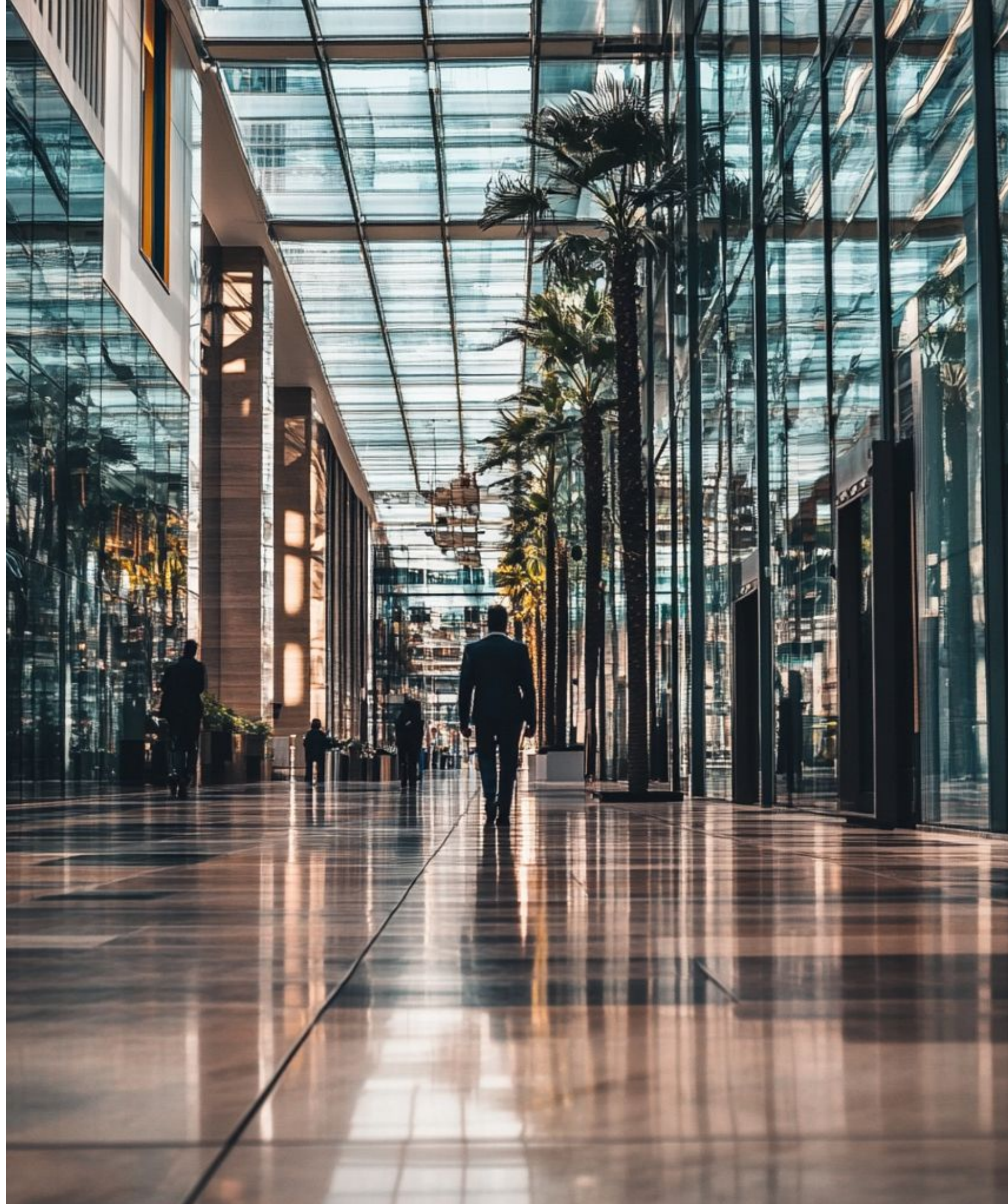
As mentioned, the PCI DSS are industry compliance, not legal. You are not legally required to protect card data this well.

- ...but your bank and all of your customers may abandon you if you don't!

If we consider compliance with all 12 requirements, the PCI DSS become one of the most exhaustive types of compliance.

- They deal with physical and logical security controls, data, devices, systems, system components, updates, personnel and visitors, logs, application development and patching, vulnerability scanning, penetration testing, network configurations... and a lot more;
- Similar demands are grouped into each requirement (e.g., everything networks is Requirement 1);





FUNDAMENTALS

FUNDAMENTALS FUNDAMENTALS OF THE PCI DSS

Usually, an organization:

- Assesses itself to gauge which requirements they must comply with;
 - ROC or SAQ;
- Then, it reduces the PCI DSS scope.
 - The PCI DSS only apply to systems/networks that “touch” card data, so reducing these is wise;
- Then, it implements controls
 - Usually, in layers. We start by defining configurations, creating diagrams, and the “big picture”, then start fleshing out specific controls for specific areas;
- Then, it updates its compliance
 - With different versions, requirements may change;

FUNDAMENTALS

FUNDAMENTALS OF THE PCI DSS

EXAMPLES

/01 HIGH LEVEL OF FLEXIBILITY

The PCI DSS have always allowed flexibility. As long as the control is strong and resilient, you can do it in various ways. v4 introduced a “Customized Approach”.

/02 KEY CHANGES MATTER

If you only have to comply with certain requirements because, for example, you don’t have online payments, if you start accepting them, then you must reassess.

/03 BEST PRACTICES

The PCI DSS cover a lot of areas due to, precisely, the weaknesses that usually exist in them. Sending plaintext data, malicious visitors, compromised WiFi...

FUNDAMENTALS

FUNDAMENTALS OF THE PCI DSS

KEY TAKEAWAYS

/01 STANDARDS + CONTROLS

The PCI DSS are a set of best practices in terms of protecting card data. Based on how you interact with card data, you'll have certain requirements.

/02 EXHAUSTIVE CONTROLS

Considering all 12 requirements, the PCI DSS cover all types of security controls. Systems, people, applications, and many more dimensions.

/03 COMPLYING

A company usually assesses what they must comply with, implements controls for the PCI DSS scope they have, and then keep them updated as changes occur.